

bin' is the scripts' directory and 'foo' is the script, the user gets the output of the 'foo' script. In a secure system, the user is not supposed to view the source-code of 'foo' by making an HTTP GET request.

Vulnerability description

Usually the following directives in 'httpd.conf' file can be considered safe for Unix/Linux (assuming that other directives haven't been insanely edited):

```
# Sample Safe Configuration for Unix/Linux
DocumentRoot "/home/webmaster/site/docroot/"
ScriptAlias /cgi-bin/ "/home/webmaster/site/docroot/cgi-bin"
```

But a similar configuration isn't safe in Windows. For instance:-

```
# Sample Unsafe Configuration for Windows
DocumentRoot "C:/Documents and Settings/webmaster/site/docroot"
ScriptAlias /cgi-bin/ "C:/Documents and Settings/webmaster/site/
docroot/cgi-bin/"
```

If the scripts' directory (represented by 'ScriptAlias') lies inside the document-root directory (represented by 'DocumentRoot') and the name of the script-alias is same as that of the directory containing the scripts then the attacker can obtain the source code of the CGI scripts by making a direct request to **http://[target]/CGI-BIN/foo**.

Apache web-server checks for the exact case mentioned in the 'ScriptAlias' directive before deciding whether the directory mentioned in the Http Get request is a scripts' directory or not. So, when Apache web server receives a request for a file in 'cgi-bin' directory, it finds it to be different from 'cgi-bin' mentioned in the 'ScriptAlias' directive. So, it concludes that it is not a script-alias. Then it checks for 'cgi-bin' directory in the document-root directory and finds it since file-names and directory-names are not case-sensitive on Windows. So, it simply sends the content of the 'foo' file as the HTTP response. It doesn't execute the 'foo' script because it isn't found in a directory pointed by script-alias.

Exploit

The vulnerability can be exploited by making a direct request to **http://[target]/CGI-BIN/foo**.

Prevention

1. Choosing a name for the 'ScriptAlias' different from the name of the actual directory will reduce the risk. For instance,